

Security Incident Response Policy

Detection, reporting, containment, and escalation requirements for suspected security incidents.

Document Owner	IT Security and Risk Management
Classification	Internal — Enterprise Policy
Version	1.0
Effective Date	01 September 2026
Review Cycle	Annual or following a significant incident

Key Rule

When in doubt, report a suspected security incident to the IT security team promptly rather than attempting to resolve or conceal it independently.

1. Purpose

- Establish a consistent process for identifying, reporting, containing, and responding to suspected security incidents.
- Reduce the impact of incidents and preserve information needed for investigation.

2. What Constitutes a Security Incident

- Suspected unauthorized access to an organizational account or system.
- Loss or theft of an organization-owned device containing organizational information.
- Accidental disclosure or external sharing of Confidential or Restricted information.
- Suspected malware, ransomware, or other malicious software on an organization-managed device.
- Unexpected account activity, repeated login failures, or other signs of possible compromise.

3. Employee Reporting Requirements

- Employees must report suspected security incidents to the IT security team as soon as possible.
- Employees should provide the time of the event, affected device or account, observed symptoms, and any relevant messages or evidence.
- Employees must not conceal or intentionally delay reporting a suspected incident.

4. Initial Response

- Do not delete potentially relevant files, logs, messages, or other evidence unless instructed by the IT security team.
- Do not attempt unauthorized forensic investigation or system modification.
- If a device is suspected of being compromised, follow instructions from the IT security team regarding network isolation or shutdown.
- If credentials may have been compromised, follow the organization's account-security instructions immediately.

5. Escalation

- The IT security team determines incident severity and coordinates technical response.
- High-impact incidents involving Confidential or Restricted information must be escalated to designated security and management contacts.
- Incidents affecting critical business services may require additional continuity and recovery procedures.

6. Evidence and Confidentiality

- Incident information must be shared only with personnel who require it for response or management.
- Incident records, logs, and collected evidence must be stored in organization-approved systems.
- Employees must not publish incident details on social media or disclose them to external parties unless authorized.

7. Recovery and Lessons Learned

- Systems may be returned to normal operation only after required security checks and authorization.
- Material incidents should be reviewed to identify corrective actions and improvements.
- Lessons learned may result in changes to controls, training, or organizational policies.